

Incident Response Report

NetSupport Manager RAT Command & Control Activity
Compromised Endpoint DESKTOP-TEYQ2NR in the EASYAS123 Domain

Incident date	28 February 2026 (C2 activity observed 19:56 UTC on 28 Feb)
Report date	5 October 2026
Prepared by	Firas, SOC Analyst (Home SOC Lab)
Evidence source	Packet capture 2026-02-28-traffic-analysis-exercise.pcap (Malware-Traffic-Analysis.net)
Incident category	Malicious code: Remote Access Trojan (RAT) with active Command & Control (C2)
Severity	CRITICAL
Status	Analysis complete. Containment, eradication and recovery actions recommended. Suricata rule SID 1000001 authored and validated against the capture.

Contents

1. Executive Summary.....	2
2. Incident Timeline & Key Metrics	3
3. Asset & Identity Scoping	3
4. Technical Analysis & Evidence Verification	5
5. Containment, Eradication & Remediation	7
6. Appendix	8

This report follows the classic incident-handling lifecycle used by NIST SP 800-61 and the SANS PICERL model: detection and analysis (Sections 2 to 4), containment, eradication and recovery (Section 5), and post-incident activity with lessons learned (Section 5.4). Indicators are defanged throughout ([.] , h x x p); refang them before loading into blocklists.

1. Executive Summary

Written for non-technical management.

1.1 Incident Overview

On 28 February 2026, analysis of captured network traffic confirmed that an internal workstation, **DESKTOP-TEYQ2NR (10.2.28.88)**, in the **EASYAS123** Active Directory domain was compromised and was under the control of a remote attacker. The machine was contacting a Command & Control (C2) server at **45.131.214[.]85** once every 60 seconds, using the protocol of **NetSupport Manager**. NetSupport Manager is a legitimate remote-administration product that criminals frequently abuse as a Remote Access Trojan (RAT). The server answered every check-in, which shows a live, two-way control channel that stayed active for at least 4 hours 20 minutes.

1.2 Risk / Impact Level

CRITICAL

A RAT gives the attacker complete remote-desktop control of the workstation: viewing the screen, running commands, moving files and harvesting data and credentials. The infected host is domain-joined and the user account **brolf** authenticated to the domain controller, so the foothold can be used to attempt **lateral movement across Active Directory**. The control channel switches to encrypted traffic, so what the attacker actually did on the machine cannot be read from the network capture.

The CRITICAL rating is based on four facts: (1) the C2 channel is confirmed and active, (2) a domain user is exposed, (3) the attacker can reach the whole desktop, and (4) independent threat intelligence already classifies the destination as botnet C2 infrastructure.

1.3 Current Status

Workstream	Status	Detail
Detection & analysis	Complete	Victim host, user, C2 channel and threat-intel context established and cross-validated with several tools.
Containment	Recommended	Actions defined in Section 5.1; they have not been executed in this exercise.
Detection engineering	Rule authored	Suricata rule SID 1000001 written and validated against the capture; deployment to edge sensors is the next step (Section 5.4).
Eradication & recovery	Pending	Disk forensics and re-image required (Sections 5.2 and 5.3).

1.4 Decisions Requested from Management

- **Authorise immediate network isolation** of DESKTOP-TEYQ2NR and a forced credential reset for user **brolf**.
- **Approve blocking** of 45.131.214[.]85 at the perimeter firewall and web proxy.
- **Approve a full re-image** of the workstation rather than clean-up in place, and a sweep of other endpoints for the same indicators.

1.5 Scope and Confidence

Confidence that the host is running NetSupport RAT C2 is **high**: it rests on protocol content, behaviour, server banner and threat-intelligence reputation that all agree. The evidence is network-only; the points that remain open (initial infection vector, attacker actions, data loss) are listed in Section 4.5.

2. Incident Timeline & Key Metrics

60 s Beacon interval (fixed)	≥ 4h 20m Observed C2 activity window	264 Total Recorded C2 Beacons	1 Compromised host and user account	8 Vendors flagging the C2 IP (VirusTotal)
---	---	--	--	--

Beacon count is derived from the observed window divided by the interval; it was not counted packet by packet.

2.1 Incident Lifecycle

Date / Time (UTC)	Event stage	Details
2026-02-28 19:55:08	Capture start / baseline	Earliest recorded activity of 10.2.28.88: a DNS SRV lookup for a domain controller sent to 10.2.28.2 (Suricata eve.json, 20:55:08 +01:00).
2026-02-28 19:56:52*	Initial detection and C2 connection established	Anomalous HTTP POST from 10.2.28.88 to 45.131.214[.]85/fakeurl[.]htm logged by Zeek (earliest legible row in the Zui evidence). The server replied, so the C2 session was live.
2026-02-28 19:57:52 onward	Active RAT beaconing	Automated 60-second heartbeat (19:56:52, 19:57:52, 19:58:52 ...) with User-Agent NetSupport Manager / 1.3. Payload starts in plaintext (CMD=POLL) then moves to encrypted parameters (CMD=ENC D, ES=1).
2026-03-01 00:16:28	Beaconing still active	Newest beacon visible in the Zeek HTTP log; the cadence is unchanged and the channel was still open at the end of the data.
Analysis phase	Detection engineering	C2 artifacts profiled; Suricata rule SID 1000001 authored and run against the capture; alerts recorded in fast.log and eve.json.

* All times are UTC taken from the Zeek ts field and Suricata eve.json (converted from +01:00).

3. Asset & Identity Scoping

The IP address alone is not a reliable identity because addresses change. The host was therefore tied to a physical device, a system name and a user identity, and each value was cross-checked in a second tool.

Asset parameter	Value	Source and method
Host system	DESKTOP-TEYQ2NR	NetBIOS Name Service (NBNS) registration
IP address	10.2.28.88	Wireshark: Statistics > Endpoints > IPv4 (highest packet and byte counts among private addresses)
MAC address	00:19:d1:b2:4d:ad	Layer 2 Ethernet frame headers
Impacted domain	EASYAS123	Kerberos AS-REQ realm field
Compromised user account	brolf	Kerberos AS-REQ cname-string field
Domain controller contacted	10.2.28.2	Destination of the Kerberos AS-REQ from 10.2.28.88 (also the DNS server)

Verification. NetworkMiner independently parsed the same capture and confirmed the IP address, the operating-system fingerprint, the computer name and the Active Directory account, without any manual display filters.

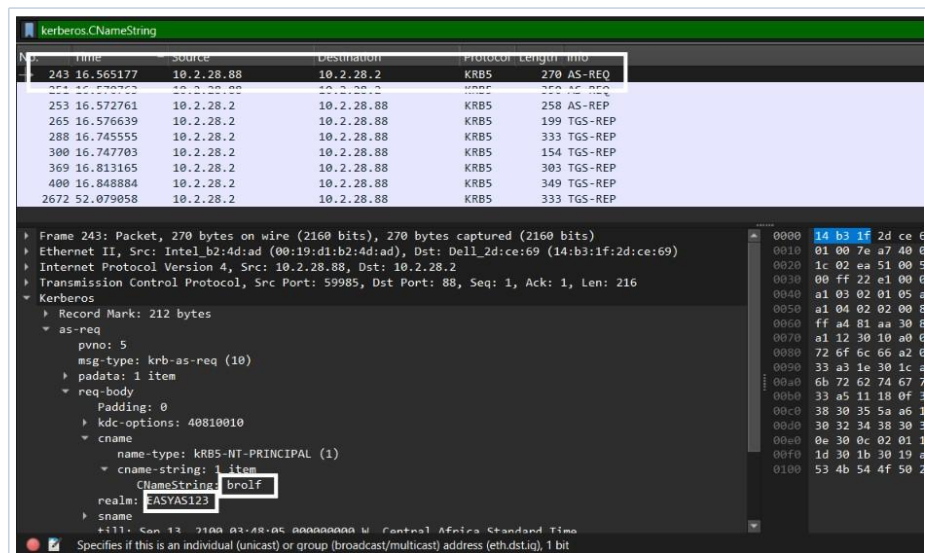


Figure 1. Wireshark filter Kerberos.CNameString : AS-REQ from 10.2.28.88 to the domain controller exposing user brolf and realm EASYAS123.

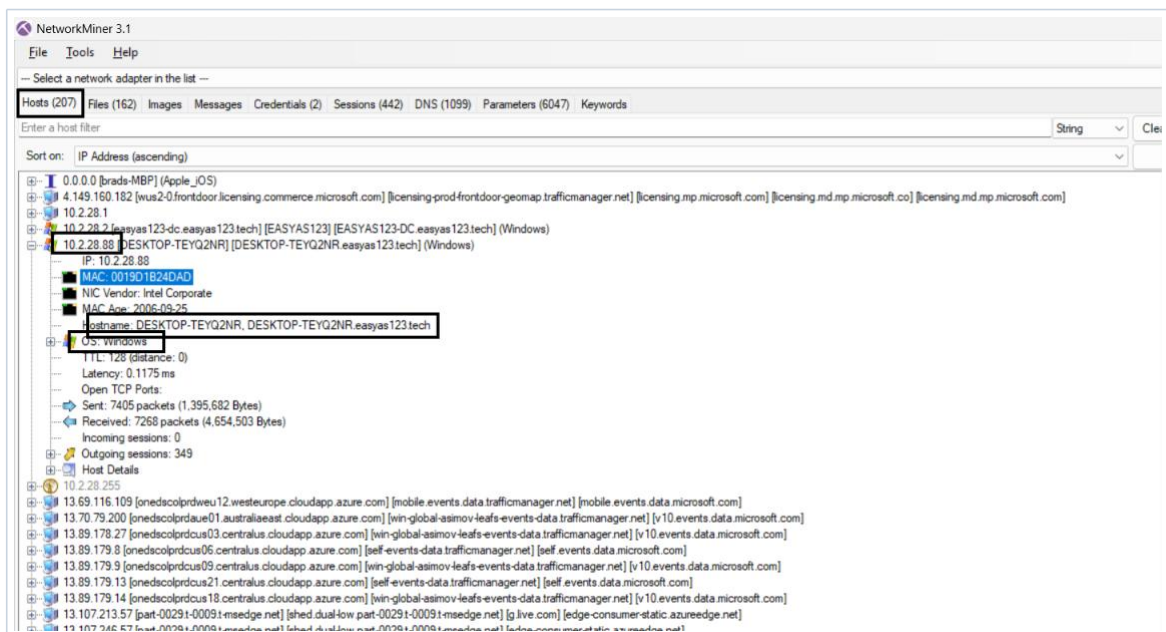


Figure 2. NetworkMiner cross-validation of host identity (Hosts and Credentials tabs).

Exposure assessment. Because the user authenticated through Kerberos from this host, the account's credentials and any Kerberos tickets held in memory must be treated as exposed. No other internal host has been scoped yet; that is an open action in Section 5.1.

4. Technical Analysis & Evidence Verification

4.1 C2 Channel Profile

C2 server	45.131.214[.]85 (no DNS name; direct IP communication)
Hosting provider	MHost LLC (hosting provider, AbuseIPDB)
Geolocation	Netherlands (VirusTotal) and Germany (AbuseIPDB). The sources disagree, which is common for hosting-provider address space; the provider, not the country, is the reliable attribute.
Protocol and port	HTTP over TCP port 80
HTTP method and URI	POST to /fakeurl[.]htm
Request User-Agent	NetSupport Manager/1.3
Content-Type	application/x-www-form-urlencoded
Server banner	NetSupport Gateway/1.92 (Windows NT) with HTTP 200 OK
Beacon interval	Exactly 60 seconds, sustained for hours
Payload behaviour	Plaintext check-in (CMD=POLL, INFO=1, ACK=1), then encrypted session data (CMD=ENC D, ES=1, DATA=...)

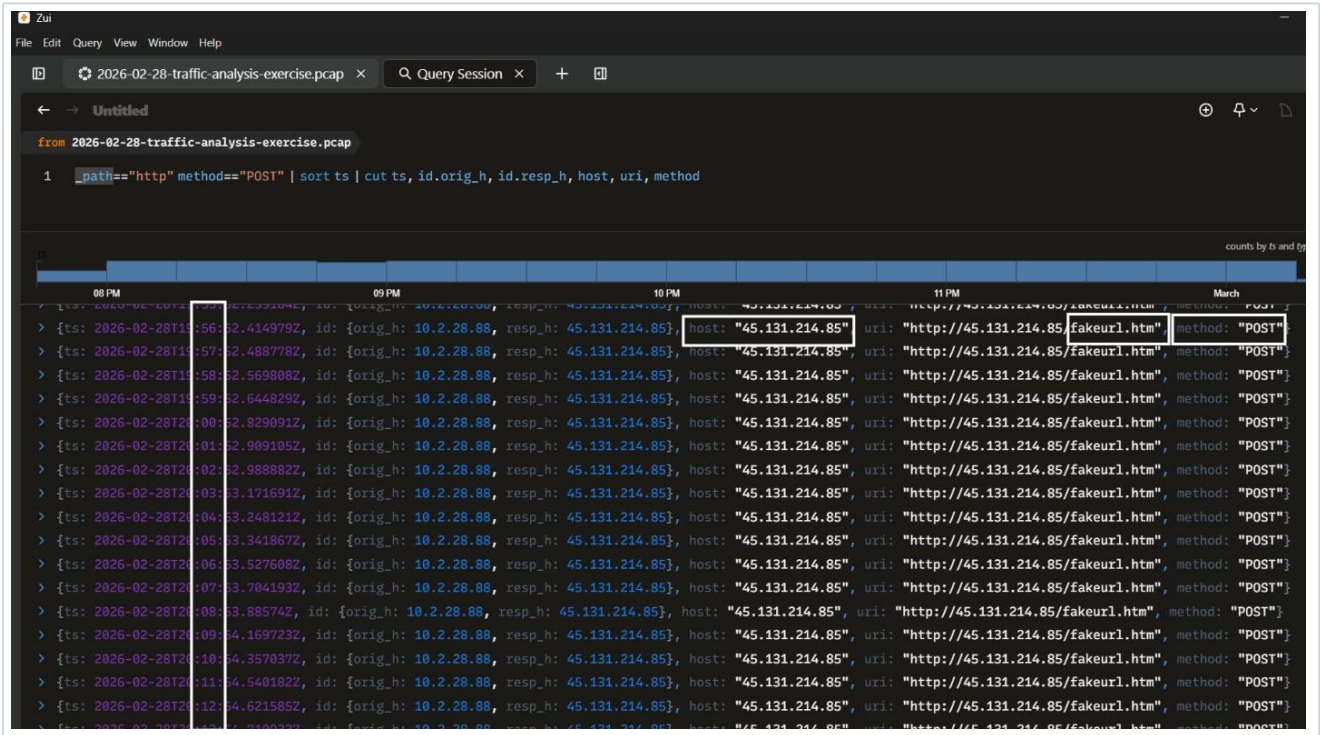


Figure 3. Zui / Zeek query of HTTP POST requests: one POST per minute from 10.2.28.88 to 45.131.214[.]85/fakeurl[.]htm.

4.2 Protocol Anomaly Analysis

No single indicator below proves malicious intent on its own. Together they match RAT behaviour and are very unlikely to be legitimate administration traffic.

Observation	Why it indicates RAT / C2 behaviour
POST requests to a static .htm page	Static pages are fetched with GET. Posting data to one means the page is only a decoy path and something else is processing the request, which is typical of C2 endpoints disguising themselves as web content.
Fixed 60-second interval	Human browsing is irregular. A metronomic cadence for hours is a machine-driven heartbeat (beaconing) asking the server whether it has a task.

Observation	Why it indicates RAT / C2 behaviour
Direct-to-IP, no domain name	Skipping DNS avoids DNS logging, domain reputation and sinkholing, and shows the client was configured with a hard-coded server address.
User-Agent NetSupport Manager/1.3 and server banner NetSupport Gateway/1.92	Both ends speak the NetSupport remote-control protocol. A managed fleet would reach an internal, sanctioned gateway; here the gateway is an external address in hosting-provider space.
Command vocabulary (CMD=POLL, CMD=ENCD, ES=1)	POLL is the check-in for tasking; ENCD with ES=1 means the session moved to encrypted data, so the operator's commands and any stolen data are no longer readable on the wire.

Conclusion. The host is performing automated C2 beaconing to a NetSupport gateway under attacker control. The NetSupport software itself is lawful; the context (external hosting address, no domain, decoy URI, fixed heartbeat, malicious reputation) is what makes this a RAT.

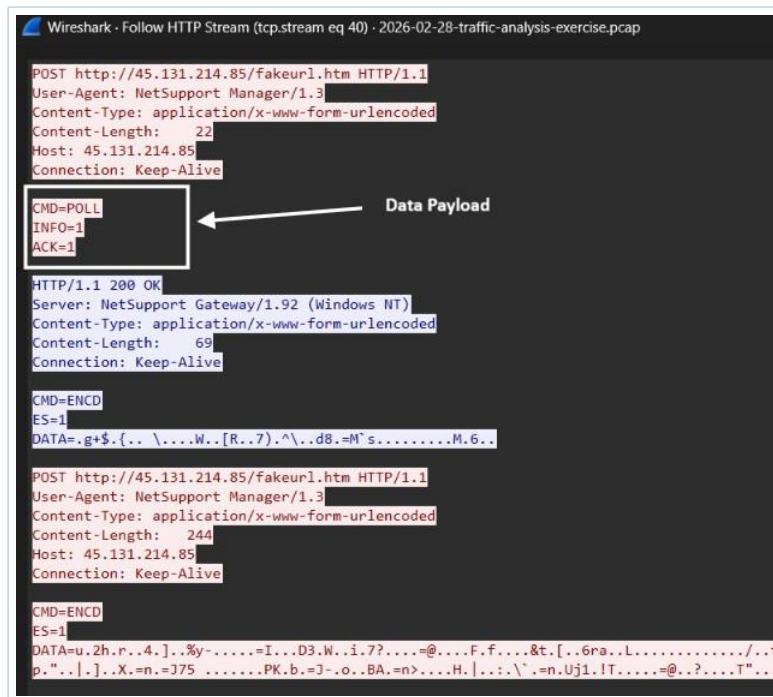


Figure 4. Wireshark Follow HTTP Stream: request with CMD=POLL (boxed), the 200 OK from NetSupport Gateway/1.92, then encrypted CMD=ENCD exchanges.

4.3 Threat Intelligence Matching

Source	Finding	Assessment
VirusTotal (IP reputation)	8 security vendors flag 45.131.214[.]85 as malicious: alphaMountain.ai, BitDefender, Dr.Web, Fortinet, G-Data, Lionix, Sophos, VIPRE.	Corroborates malicious infrastructure.
VirusTotal (community comments)	Threat type botnet_cc, confidence 100%, country Netherlands.	Infrastructure already verified by analysts and platforms as C2.
VirusTotal (relations)	Two files communicate with this IP (SHA-256 in Appendix 6.1).	Additional samples to hunt for; not extracted from this capture.
AbuseIPDB	ISP MHost LLC (hosting provider), country Germany, no user reports yet.	Hosting-provider space fits disposable C2; the lack of reports means the IP is not widely known.

The behaviour seen in the capture (NetSupport protocol, 60-second POST beacon, direct-IP C2) agrees with the reputation data, so the two lines of evidence reinforce each other.

4.4 Evidence Verification Matrix

Finding	Primary tool	Cross-validation
Victim IP, MAC, hostname	Wireshark (Endpoints, DHCP/NBNS, frame headers)	NetworkMiner Hosts tab
User account and domain	Wireshark Kerberos AS-REQ	NetworkMiner Credentials tab
C2 beaconing and 60 s cadence	Zui / Zeek http log	Wireshark HTTP stream
Payload structure (POLL / ENCD)	Wireshark Follow HTTP Stream	Zeek log of method and URI
C2 reputation	VirusTotal	AbuseIPDB
Detection logic	Suricata offline PCAP replay	fast.log and eve.json

4.5 Limitations and Open Questions

- **Initial access vector is unknown.** No executable or DLL was transferred over HTTP in the capture, so no payload could be extracted for hashing. The infection probably occurred before the capture window or over a channel not visible here.
- **Encrypted C2 content.** After `CMD=ENCD` the session cannot be read, so attacker actions, data theft and lateral movement cannot be confirmed or excluded from the capture.
- **Network-only evidence.** No endpoint telemetry, memory or disk data was available; persistence mechanisms are therefore unconfirmed.
- **Single-host scope.** Other hosts have not been checked against the indicators.

5. Containment, Eradication & Remediation

Actions below are **recommendations** derived from the analysis. They are ordered by urgency.

5.1 Immediate Containment

#	Action	Details	When
1	Isolate asset	Disconnect DESKTOP-TEYQ2NR (10.2.28.88) from the network immediately: disable the NIC, port-isolate the switch port or use EDR network containment. This stops the C2 channel and prevents lateral movement. Keep the machine powered on until a memory image is captured, then shut it down.	Immediately
2	Revoke credentials	Reset the Active Directory password for user brolf and terminate all active Kerberos ticket-granting sessions: disable the account, force log-off of active sessions and confirm no valid tickets remain (default TGT lifetime is 10 hours unless policy differs). Review any other account that logged on to the host.	Immediately
3	Block infrastructure	Add 45.131.214[.]85 to the perimeter firewall and web-proxy blocklists in both directions and log hits so that any other infected host is revealed.	Immediately
4	Preserve evidence	Retain the PCAP, Zeek logs, Suricata <code>eve.json</code> , the memory image and file hashes, and record chain of custody before any remediation alters the host.	Immediately
5	Scope the incident	Search proxy, firewall, Zeek and EDR data for other hosts contacting 45.131.214[.]85 or using the <code>NetSupport Manager / 1.3</code> User-Agent; check other endpoints for an unauthorised NetSupport client.	Within 24 h

5.2 Eradication

- Create a **forensic disk image** of DESKTOP-TEYQ2NR and analyse the image offline; carve out and identify the persistence mechanisms: **Registry Run keys**, **Scheduled Tasks** and **malicious services** that launch the NetSupport RAT client.
- Hunting hints from public NetSupport RAT reporting (not observed in this capture): `client32.exe`, `client32.ini` and `NSM.lic` in user-writable folders.

- Determine the **initial access vector** (phishing attachment or link, malicious download) from e-mail gateway, proxy and endpoint logs, because it cannot be recovered from this capture.
- Search the two VirusTotal-related SHA-256 hashes (Appendix 6.1) across the estate.

5.3 Recovery

- **Re-image the host** from a known-good baseline before it returns to production; do not clean it in place.
- Re-join the domain with a fresh computer-account password and restore user data only from verified-clean sources, scanned before restoration.
- Re-enable account brof only with new credentials (and MFA where available) and brief the user on the incident.
- Return the host to service only after the re-image is verified and the EDR agent is healthy, then apply heightened monitoring for any traffic to the Appendix 6.1 indicators and for unusual Kerberos activity from the host and user.

5.4 Lessons Learned & Long-Term Defenses

Control	Recommendation
IDS signature deployment	Deploy custom Suricata rule SID 1000001 across all enterprise network taps and sensors and forward its alerts to the SIEM at high priority.
Egress filtering	Block direct outbound HTTP/HTTPS traffic to IP addresses that bypasses the corporate web proxies; require proxy use for all web egress.
Detection depth	SID 1000001 matches one URI, so an operator changing the path would evade it. Add (not yet authored) detections on the NetSupport User-Agent, on the C2 destination and on fixed-interval beaconing in Zeek data.
Application control	Allow-list approved remote-administration tools; alert on NetSupport client installation or execution outside IT-managed systems.
Endpoint and identity	Ensure EDR coverage with persistence monitoring (Run keys, tasks, services); monitor Kerberos anomalies; apply least privilege and MFA.
Threat intelligence	Load the Appendix 6.1 indicators into the SIEM, firewall and proxy, and retro-hunt against historical logs.
People and process	Update the IR playbook with this scenario and run phishing-awareness training, since the delivery method is still unidentified.

6. Appendix

6.1 Complete Defanged IOC Table

Copy-paste ready. Refang ([.] to ., h x x p to h t t p) before loading into enforcement tools.

Type	Indicator	Context
IPv4	45.131.214[.]85	C2 server; 8 vendors flag as malicious; <i>botnet_cc</i>
Port / protocol	80/tcp (HTTP)	C2 channel
URL	hxxp://45.131.214[.]85/fakeurl[.]htm	Beacon endpoint
URI path	/fakeurl[.]htm	Decoy static path receiving POST
Host header	45.131.214[.]85	Raw IP used as Host value
HTTP method	POST	Every 60 seconds
User-Agent	NetSupport Manager/1.3	Client side of NetSupport protocol

Type	Indicator	Context
Server banner	NetSupport Gateway/1.92 (Windows NT)	C2 response header
Payload string	CMD=POLL&INFO=1&ACK=1	Plaintext check-in
Payload string	CMD=ENCD&ES=1	Encrypted session marker
SHA-256	712c7e845543e6ddd07f724b6f9a9a0e2c84fdf6d8956fdd2bef94775b2ef707	File communicating with the C2 IP (VirusTotal relation; not extracted from PCAP)
SHA-256	c9e5bb7a368280d771edcfdb33717a3130560d2bb71773ab1aaffe0eb585fd2c	File communicating with the C2 IP (VirusTotal relation; not extracted from PCAP)
Detection	sid:1000001	Suricata rule for POST to the decoy URI

Affected assets (not indicators of compromise): host DESKTOP-TEYQ2NR, 10.2.28.88, MAC 00:19:d1:b2:4d:ad, domain EASYAS123, user broflf (see Section 3).

6.2 Detection Signature (Suricata)

Stored in `rules/custom_detection.rules` (single line). Shown here with backslash line continuations for readability.

```
alert http $HOME_NET any -> $EXTERNAL_NET any \
(msg:"CUSTOM DETECT Malicious C2 HTTP POST Request to URI (/fakeurl.htm)"; \
flow:established,to_server; \
http.method; content:"POST"; \
http.uri; content:"/fakeurl.htm"; fast_pattern; \
classtype:trojan-activity; sid:1000001; rev:1;)
```

Validation. The rule was tested offline by replaying the capture through Suricata:

```
& "C:\Program Files\Suricata\suricata.exe" -c "C:\Program Files\Suricata\suricata.yaml" \
-s rules\custom_detection.rules -r sample_infection.pcap -l logs
```

Alerts were reviewed in `logs/fast.log` (text summary) and `logs/eve.json` (structured telemetry for the SIEM); screenshots are in the repository under `screenshots/`.

6.3 Tooling and References

Item	Use in this investigation
Wireshark	Deep packet inspection, display filters, HTTP stream reconstruction
NetworkMiner	Passive forensics: host, credential and session cross-validation
Zui / Brim (Zeek)	Indexed Zeek logs: HTTP triage and beaconing detection
Suricata	IDS engine for rule testing against the capture
VirusTotal, AbuseIPDB	OSINT reputation and relations for the C2 IP
Malware-Traffic-Analysis.net	Source of the training capture (2026-02-28 exercise)
NIST SP 800-61; SANS PICERL	Incident-handling frameworks used to structure this report